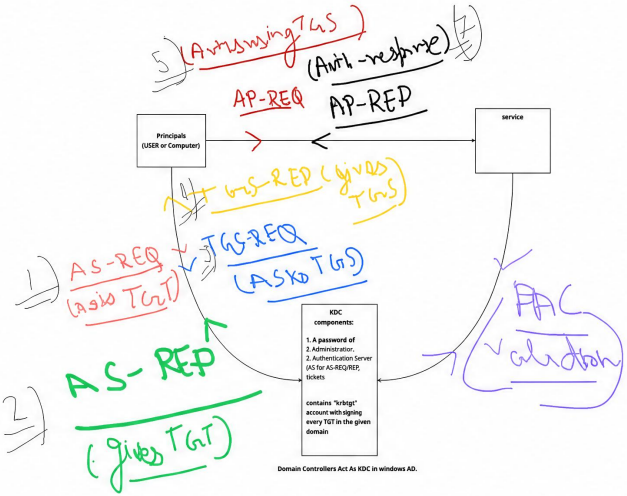
1. The Normal Login Check
   - **User requests ticket:** You ask the Key Distribution Center (KDC) for a Ticket Granting Ticket (TGT).

2. The Vulnerable State (DO_NOT_REQ_PREAUTH)
   - **Pre-auth disabled:** An administrator (or old template) checks the box *"Do not require Kerberos preauthentication"* (UF_DONT_REQUIRE_PREAUTH).
   - **KDC skips check:** When this flag is set, the KDC does not demand proof of identity first.
   - **TGT returned immediately:** The KDC sends the TGT and the AS-REP (Authentication Service Response) containing session keys and data signed/encrypted with the user's password hash.



Domain Controllers Act As KDC in windows AD.

Tgt: Saved in User's LSASS memory as domain_userid to ask for TGS of specific services.
TGS: saved in LSASS memory, used to authenticate user to a specific service and contain it's resources.

PAC: Contains additional info about the principal to which the ticket belongs to, it's a structure attached to tickets.This can include Role info, Domain group membership, User information, and more. When presenting a new ticket to the service, ex. krbtgt validate TGT, extract the PAC to determine auth and rights. When the service accepting a new ticket from a user, they use highly recommended it and determines to be authorized.

WheatID: Krcc facilities enforcing signature and PAC trust, the user across whatever explicit claims (SID, groups memberships, or administrative flags) are arranged inside the Kerberos ticket's PAC even if those claims are forged, altered, or replayed.

Authentication Flow:

i. AS-REQ (Authentication Service Request)

The request contains the principal's name, the Kerberos realm (i.e. domain name), the target service's name (always krbtgt for TGTs), and a list of encryption types that the client supports (in order of preference).

ii.AS-REP (Authentication Service Response)

- **KDC looks up account:** The KDC checks Active Directory for your user principal.
- **Pre-authentication required:** By default, Windows demands pre-authentication (proving who you are with your password hash) before giving a TGT;: if you bypass it, **the most commonly used mechanism is an encrypted timestamp. The client encrypts the current time using a hash derived from the principal's own plaintext password.)**
- **Error response:** If pre-auth is not turned off, the KDC replies with KDC_ERR_PREAUTH_REQUIRED. It also sends a timestamp encrypted with your account's NTLM password hash.

The KDC then generates a new TGT and logon session key for the principal, and returns them in an **AS-REP** message.

iii. TGS-REQ

The client constructs a Ticket-Granting Service Request (TGS-REQ) message which contains the SPN of the target service (e.g. cifs/computer.domain.com), the principal's TGT, and an authenticator.

iv. TGS-REP

Decrypt the TGT: The KDC uses the **krbtgt hash** to decrypt the Ticket Granting Ticket (TGT).
Recover the session key: Decrypting the TGT reveals a copy of the **logon session key** stored inside its EncTicketPart.
Decrypt the authenticator: The KDC uses this recovered logon session key to decrypt and inspect the **authenticator.**
Verify the request: The KDC checks the requested details to validate and verify the **TGS-REQ**.
Lookup the SPN: Once verified, the KDC searches for the requested **Service Principal Name** (SPN) in Active Directory.
Identify the service principal: This lookup determines whether the target service is associated with a user account or a computer account.
Validation check: The Key Distribution Center (KDC) verifies that the provided authenticator and Service Principal Name (SPN) are technically valid.
Ticket generation: The KDC creates a new service ticket for the requested service.
Client response: The KDC bundles the service ticket and session key into a TGS-REP message and sends it back to the client.
PAC inclusion: The KDC copies the Privilege Attribute Certificate (PAC) from the client's Ticket-Granting Ticket (TGT) and embeds it inside the new service ticket by default.

v. AP-REQ

The **AP-REQ** includes the service ticket and another authenticator, which has been encrypted with the service session key.

vi. AP-REP

Optional Service Response: The service does not always need to respond to the **AP-REQ**.
Mutual Authentication Check: Clients use the ap-options field in the **AP-REQ** to specify if mutual authentication is required (which is typical but not always).
AP-REP Requirement: If mutual authentication is requested, the service must respond to the client with an **AP-REP**.
Timestamp Re-encryption: The service generates the **AP-REP** by re-encrypting the timestamp received from the client's authenticator and sending it back.
Client Verification: The client verifies the identity of the service by matching the returned timestamp with the one it originally sent.
Proof of Legitimacy: Successful verification proves the service is legitimate because only the real service has the **session key** needed to decrypt the original authenticator.
Session Termination: The client can immediately stop all further communication if it cannot verify the AP-**REP** response.